OWASP Compliance Evidence - ConstructPro

1. Assessment basis

This document records source inspection and the focused checks executed below. It is suitable as an evidence register for the Final Report, but does not establish full compliance. A control present in code is distinguished from a passing deployment test, a clean dependency scan, and an approved design review.

Repository	Inspected HEAD	Working-tree qualification
backend	8833e971ecc39f58ef2228c76d560ffc92d22add	Clean at inspection
frontend	683589a7ddf5eabf38980d252e07a3f8ae73ff9d	Clean at inspection
infra	9048b0ff52f73edef30c64a25c8f766722294627	Clean at inspection
tests	e3bbec14c6d6acb3c14f66ffcfcf9af83c386799	Clean at inspection

Status definitions:

- Partial = some implementation evidence exists but the complete requirement is not demonstrated.
- Implemented = source satisfies the stated mechanism.

2. Compliance matrix

ID	Required mitigation	Assessment
A01	Role checks on every endpoint; unauthorized role tests return 403	Implemented
A02	bcrypt cost ≥12; tokens stored as hashes; TLS enforced	Implemented
A03	Parameterized queries/ORM throughout; validated and sanitized input	Implemented
A04	Threat model in SDS Security section; design reviewed against it	Partial
A05	Default credentials removed; production errors hide stack traces	Implemented

A06	Dependency scan in CI; no high/critical vulnerabilities	Implemented
A07	Lockout after N failures; secure sessions; MFA optional	Partial
A08	Committed lockfiles; pipeline verifies integrity	Implemented
A09	All auth events/errors/data access logged without PII/secrets	Implemented
A10	Validate external URL inputs; permitted-domain allow-list	Implemented

2.1 A01 - Broken Access Control

Implemented evidence:

- JwtAuthGuard (backend/apps/api-gateway/src/guards/jwt-auth.guard.ts), canActivate, rejects missing/malformed bearer credentials with 401 and asks auth-service /auth/me to validate the identity.

- RolesGuard (backend/apps/api-gateway/src/guards/roles.guard.ts), canActivate, checks normalized roles and throws ForbiddenException for insufficient roles. It permits execution when role metadata is absent, so attaching the guard alone does not establish a role policy.

- Explicit role policies appear in users (backend/apps/api-gateway/src/controllers/users-gateway.controller.ts), projects (backend/apps/api-gateway/src/controllers/projects-gateway.controller.ts), quotations (backend/apps/api-gateway/src/controllers/quotations-gateway.controller.ts), and client portal (backend/apps/api-gateway/src/controllers/client-portal-gateway.controller.ts) gateway controllers.

- Project access policy (backend/libs/common/src/project-access/project-access.policy.ts), project access service (backend/apps/project-service/src/project-access.service.ts), and client portal access service (backend/apps/client-service/src/client-portal-access.service.ts) provide resource-level authorization. ADR-15 (backend/docs/adr/ADR-15-client-portal-ownership-filtered-read-access.md) explicitly identifies service query filtering rather than PostgreSQL RLS.

- Frontend dashboard access (frontend/src/lib/dashboardAccess.ts) restricts UI navigation. This supports usability; server authorization is still required.

- Authorization tests (tests/e2e/authorization.spec.ts) assert 401 for anonymous callers and 403 for a configured restricted role. Management authorization tests (tests/e2e/management-authorization.spec.ts) also assert 403. Credential-dependent cases use test.skip, so their existence is not proof they executed.

2.2 A02 - Cryptographic Failures

Implemented evidence:

- AuthService.register (backend/apps/auth-service/src/auth.service.ts) hashes passwords with bcrypt.hash(password, 12); validateUser uses bcrypt.compare.

- UserService (backend/apps/user-service/src/user.service.ts) defines BCRYPT_SALT_ROUNDS = 12 for administrator-created users. Seed (backend/prisma/seed.ts) also hashes its password at cost 12.

- Calendar token encryption (backend/apps/calender-service/src/token-encryption.service.ts) uses AES-256-GCM, a 32-byte configured key, random IVs, and authentication tags for recoverable provider tokens.

2.3 A03 - Injection

Implemented evidence:

- Prisma repositories perform structured operations, for example client repository (backend/apps/client-service/src/repository/client.repository.ts) and payment repository (backend/apps/payment-service/src/repositories/payment.repository.ts). Payment row-lock SQL uses tagged $queryRaw parameters.

- Gateway bootstrap (backend/apps/api-gateway/src/main.ts) installs ValidationPipe({ whitelist: true, transform: true }). Document DTOs (backend/apps/document-service/src/dto/authorize-document-upload.dto.ts) validate filename, MIME type, size, and inherited category fields. User Zod pipe (backend/apps/user-service/src/pipes/zod-validation.pipe.ts) and DTO schemas provide additional input validation.

- Document DTO tests (backend/test/document-service/document-dto.spec.ts) were executed successfully in the focused run.

2.4 A04 - Insecure Design

Implemented evidence:

- Security model (documents/design/security_model.md) documents authentication, authorization, data protection, validation, and intended OWASP controls.

- ADR-11 (backend/docs/adr/ADR-11-project-and-task-service-boundaries.md) records architectural boundaries and pending review work. ADR-15 (backend/docs/adr/ADR-15-client-portal-ownership-filtered-read-access.md) records ownership filtering and the SDS RLS deviation.

2.5 A05 - Security Misconfiguration

Implemented evidence:

- Gateway exception filter (backend/apps/api-gateway/src/filters/http-exception.filter.ts) returns a generic message for unexpected Error objects when NODE_ENV=production; response payloads do not include an explicit stack field.

- CI workflows consume GitHub secrets rather than embedding deployment secret values: backend workflow (infra/.github/workflows/backend-ci.yml), test workflow (infra/.github/workflows/tests-ci.yml).

2.6 A06 - Vulnerable Components

Implemented evidence:

- Reusable backend (infra/.github/workflows/backend-ci.yml), frontend (infra/.github/workflows/frontend-ci.yml), and tests (infra/.github/workflows/tests-ci.yml) workflows run blocking npm audit --audit-level=high, covering development and production dependencies. The inspected audit steps do not use continue-on-error.

- Infra contains workflow and performance tooling without an npm package manifest; its own CI (infra/.github/workflows/ci.yml) validates workflows and the performance runner. An npm scan cannot cover container images or GitHub Actions dependencies.

2.7 A07 - Authentication Failures

Implemented evidence:

- AuthService (backend/apps/auth-service/src/auth.service.ts) compares password hashes, uses a generic invalid-credentials response, and issues access/refresh JWTs with default expiries of 15 minutes/7 days. These defaults can be overridden by configuration.

- Shared Axios client (frontend/src/lib/axios.ts) implements automatic refresh behavior. Google session tests (backend/test/auth-service/google-session.spec.ts) and frontend Google auth tests (frontend/test/google-auth.test.mjs) passed in the focused run.

2.8 A08 - Software and Data Integrity Failures

Implemented evidence:

- git ls-files package-lock.json confirmed tracked lockfiles in backend (backend/package-lock.json), frontend (frontend/package-lock.json), and tests (tests/package-lock.json).

- All three reusable CI workflows install with npm ci, which checks package/lock consistency and verifies available package integrity metadata during installation.

2.9 A09 - Security Logging and Monitoring Failures

Implemented evidence:

- Gateway exception filter (backend/apps/api-gateway/src/filters/http-exception.filter.ts) logs status, code, trace ID, message, and URL. JWT guard (backend/apps/api-gateway/src/guards/jwt-auth.guard.ts) logs token-validation failure codes.

- Auth gateway (backend/apps/api-gateway/src/controllers/auth-gateway.controller.ts), forwardOAuth, logs bounded failure metadata and explicitly avoids logging authorization codes, locations, tokens, and bodies.

- LoggingInterceptor (backend/libs/common/src/interceptors/logging.interceptor.ts) records method, URL, and duration for successful responses, but no registration/use of this interceptor was found in the inspected application sources. Its definition alone is not evidence of active audit coverage.

2.10 A10 - Server-Side Request Forgery

Implemented evidence:

- AI provider (backend/apps/ai-service/src/ai-provider.service.ts) calls a fixed HTTPS OpenRouter endpoint rather than a request-supplied arbitrary URL.

- Document upload DTO (backend/apps/document-service/src/dto/authorize-document-upload.dto.ts) accepts file metadata rather than an arbitrary download URL. Document service (backend/apps/document-service/src/document.service.ts) creates storage identifiers server-side.

- Cloudinary service (backend/libs/common/src/cloudinary/cloudinary.service.ts), downloadAuthenticatedAssetBytes, derives URLs through the provider SDK, rejects redirects with redirect: 'error', uses a timeout, and bounds downloaded bytes.

- OAuth forwarding (backend/apps/api-gateway/src/controllers/auth-gateway.controller.ts) disables automatic redirects and validates the Google authorization origin. This is a useful redirect control, not a universal SSRF allow-list.

3. Checks executed for this assessment

All commands below were run on 23 October 2026. Passing checks are narrowly scoped and do not replace penetration testing or release CI.

Repository	Command (run from repository root)	Observed result
backend	.\node_modules\.bin\jest.cmd --config jest.unit.config.js --runInBand --runTestsByPath test/common/project-access.policy.spec.ts test/auth-service/google-session.spec.ts test/common/cloudinary.service.spec.ts test/document-service/document-dto.spec.ts	4 suites, 65 tests passed; initial sandbox temp-directory failure was resolved by rerunning with approval
frontend	node --test test/roles.test.mjs test/dashboard-access.test.mjs test/google-auth.test.mjs	15 tests passed, no skips
infra	node --test tests/performance/runner.test.mjs	5 tests passed, no skips; validates bounded performance tooling, not deployed OWASP compliance

tests	.\node_modules\.bin\playwright.cmd test --list	44 tests discovered in 9 files; discovery only, no deployed assertions executed

The tests caller only enables deployed E2E on workflow_dispatch. It does not forward the accountant credentials referenced by management-authorization.spec.ts, and does not forward several optional client-portal inputs supported by the reusable workflow. Configure these explicitly and retain skip counts; a green discovery/validation job must not be presented as a completed authorization test run.